SECURITY · PENETRATION TEST RESPONSE

Response to the penetration test

Our response to Haboob's web penetration test of the TOURISE 2027 registration platform (report 72, version 1.0, 15 September 2026).

To: **Saudi Tourism Authority (STA) and Haboob** · Date: **13 October 2026** · Classification: **CONFIDENTIAL**

1. Summary

Haboob assessed `register.tourise.com` and the API behind it from the internet on 14 and 15 September 2026 and reported five findings, all rated Medium. We verified each one against the application's source code and the production configuration.

All five findings are accepted. Four are fixed. For the fifth (M-005) we have reduced the risk and propose that the remainder be accepted, for the reason given in section 6. During the review we also found and fixed three related weaknesses that the test did not reach (section 7).

ID	Finding	Severity	Our position	Status
M-001-072	Outdated Next.js version	MEDIUM	Accepted	FIXED
M-002-072	Improper error handling	MEDIUM	Accepted	FIXED
M-003-072	Information disclosure (database columns)	MEDIUM	Accepted, wider than reported	FIXED
M-004-072	OTP bypass	MEDIUM	Partially accepted, a related weakness fixed	FIXED
M-005-072	User enumeration	MEDIUM	Accepted, risk reduced	PARTIAL

Status at 13 October 2026. Debug output is already disabled on production (M-002). The other changes are complete and covered by automated tests, and reach production with the next release. We will confirm the release date to STA, and ask that the retest (section 8) takes place after it.

2. M-001-072 · Outdated Next.js version · ACCEPTED

Both Next.js applications of the platform ran version 15.5.19: the public registration site in scope, and the administration panel, which was not tested but shares the version.

Done. Both are upgraded to **Next.js 15.5.27**, the latest release of the supported 15.x line. It includes the fixes for the eight CVEs listed in the report (CVE-2026-64641 to CVE-2026-64649, fixed in 15.5.21) and the later August and September 2026 Next.js security releases. A move to Next.js 16 is planned separately.

3. M-002-072 · Improper error handling · ACCEPTED

Cause. The production API ran with the framework's debug mode enabled. Unhandled errors therefore returned the exception class, server file paths and a stack trace, and the two database errors the testers triggered also returned connection details and the submitted form data.

Done.

- **Debug mode is disabled in the production configuration.** Error responses carry a status and a short message only: no exception class, file path, stack trace or SQL.
- **Error handling is hardened.** Client errors keep their correct status (401, 403, 405, 422) with a generic message; every unexpected error answers only "Internal server error." Automated tests assert this with debug mode off, the production configuration.
- **The errors behind the evidence.** The database error on `/api/guests/check-unique` can no longer occur (M-003). An over-long value in one registration field still fails, but now as a generic error with no detail; validation of that field is scheduled.
- **Debugging tools.** The platform has no request inspector or log viewer. The framework's error page tool is a development-only dependency; that its endpoint is unreachable on production is part of the retest (section 8).

4. M-003-072 · Information disclosure (database columns) · ACCEPTED

Cause. The email availability check took the name of the database column to search from the request. Unknown names produced database errors that revealed the schema (the finding), and any existing column could be queried, so the endpoint answered whether a given value existed in other columns too.

Done.

- **The endpoint checks email only.** Any other `type` is refused with `422`, and the answer is the same whether or not the value exists, so it reveals nothing.
- **The comparison is fixed on the server**, so no request can change which column is searched.
- **No guest record is ever returned.** An edit mode used to return the full record to a caller who knew a guest's internal identifier; it now answers only whether the email is free.

5. M-004-072 · OTP bypass · PARTIALLY ACCEPTED

What the report shows. Changing the email confirmation response from "wrong token" to "Success" lets the form move on to its next step.

Our analysis. That response only controls the browser's progress through the form. The registration itself is checked again on the server, which refuses it without a valid code. The report's evidence ends at the next form step and does not show a registration completing; manipulating the response alone does not complete one.

What we found and fixed. The server's check accepted any valid code, without matching it to the email address being registered. Someone could therefore obtain a code for their own address and use it to

register a different one. **A code is now accepted only together with the address it was sent to**, and is deleted once used. The request-an-invitation form and the mobile app already worked this way.

The other recommendations. Codes are eight random letters and digits, so guessing one is not practical, and a used code cannot be reused. An expiry window for email codes is scheduled.

6. M-005-072 · User enumeration · ACCEPTED, RISK REDUCED

Confirmed. The registration form's email lookup answered whether an address was already registered. A second lookup, on the request-an-invitation form, did the same and also said whether an address had already asked; it was added after the test.

Decision. Telling a returning guest at the email field that they are already registered is deliberate: attendees are invited, and a person registering twice needs to know why. The generic message the report suggests would leave them without an explanation.

Done.

- **Both lookups now require a valid Google reCAPTCHA token** on every request, issued to a browser on the platform's own site; a request without one is refused.
- **Partner integrations are unaffected.** They use a separate endpoint that requires an API key and an approved server address.
- **Hardening of the reCAPTCHA checks** (score threshold) across the public forms is under review.

Residual risk. A person can still check a single address by hand through the form, as any returning guest does. Checking addresses in bulk now needs a fresh challenge token for each one. **We propose that STA accepts this residual risk.** If STA prefers the generic message, we will implement it, informing a returning guest by email instead of on screen.

7. Further measures from our review

Area	Finding	Done
Error statuses	With debug mode off, the previous error handler answered authentication, permission and validation errors as `500`	Correct statuses with generic messages (section 3)
Email lookup (second)	The request-an-invitation lookup also answered for any address	reCAPTCHA required (section 6)
Guest record	The availability check could return a full guest record	Never returned (section 4)
Cross-origin access	Reviewed	The API accepts cross-origin requests only from the platform's own public site and administration panel (verified in the production configuration)

8. Retest

We ask Haboob to retest the five findings after the release. The expected results:

ID	Request	Expected
M-001-072	The Next.js version in the public site's scripts	15.5.27 or later
M-002-072	`GET https://api-register.tourise.com/api/guests/check-unique`	`405` with a message only: no `exception`, `file`, `line` or `trace`
M-002-072	`GET https://api-register.tourise.com/_ignition/health-check`	`404`
M-003-072	`POST /api/guests/check-unique` with `type` set to a column name, known or unknown	`422`, the same body either way, no database error
M-004-072	Request an email code for address A, then submit a registration for address B with that code	Registration refused
M-005-072	`POST /api/guests/check-unique` (and `/api/invitation-requests/check-unique`) without a reCAPTCHA token	`403`
M-005-072	The same lookup through the registration form in a browser	Works, with the "already registered" message for a registered address

9. Change references

For traceability, the changes by application. Each is covered by automated tests that run with debug mode off.

Finding	Backend (API)	Public site	Administration panel
M-001		`242552d`	`be036e9`
M-002	`c8a1885`		
M-003, M-004	`d5453ef`		
M-005	`b628d48`	`487dd43`	